

<This issue is referenced from a ****SPAM****/nonsense CVE with no explanation and no good reason. Ignore it as there is no actual vulnerability here> #6772

🔒 Closed as not planned



x1280 opened on May 31, 2022 · edited by x1280

Edits ▾ ⋮

No description provided.

6

6

2



x1280 added **bug** on May 31, 2022



Dreamsorcerer on Jun 1, 2022

Member ⋮

The code appears to be catching a `HttpProcessingError` exception:

https://github.com/google/oss-fuzz/blob/master/projects/aiohttp/fuzz_http_parser.py#L42

So, maybe our parser should consider catching and rethrowing this exception.



jrobbins-LiveData mentioned this on Jun 25, 2022



pip-audit flagging aiohttp: <https://github.com/advisories/GHSA-rwqr-c348-m5wr> #6801



EDM115 mentioned this on Jun 27, 2022



[Potential security breach EDM115/unzip-bot#37](#)



webknjaz on Jun 27, 2022 · edited by webknjaz

Edits ▾ Member ⋮

[Uploading crash.zip...](#)

This is a link to the current issue, not an actual attachment. Do you have any proof that this is actually a problem?

Denial of service

Why do you think it's expected?

```
ValueError: Invalid IPv6 URL
Traceback (most recent call last):
  File "fuzz_http_parser.py", line 32, in TestOneInput
  File "aiohttp/_http_parser.pyx", line 551, in
aiohttp._http_parser.HttpParser.feed_data
  File "aiohttp/_http_parser.pyx", line 701, in
aiohttp._http_parser.cb_on_header_field
  File "aiohttp/_http_parser.pyx", line 627, in
aiohttp._http_parser.HttpRequestParser._on_status_complete
  File "yarl/_url.py", line 151, in __new__
  File "urllib/parse.py", line 464, in urlsplit
```

This only demonstrates a traceback coming from stdlib (urllib) and yarl. So what's an actual complaint in the aiohttp-land?

giorgiop on Jun 27, 2022

FYI <https://security.snyk.io/vuln/SNYK-PYTHON-AIOHTTP-2934978>

Rongronggg9 on Jun 27, 2022 · edited by Rongronggg9

Edits ▾ Contributor ⋮

Now everyone gets informed that there is a vulnerability "waiting for a PoC", but everyone just can't see any evidence indicating that aiohttp is vulnerable.

[CVE-2022-33124](#)

**** DISPUTED **** AIOHTTP 3.8.1 can report a "ValueError: Invalid IPv6 URL" outcome, which can lead to a Denial of Service (DoS). NOTE: multiple third parties dispute this issue because there is no example of a context in which denial of service would occur, and **many common contexts have exception handling in the calling application.**

Without any PoC, if only raising an exception can be considered to be a DoS vulnerability instead of a bug or expected behavior, well, should CVE-ID be 64bit long?

Denial of Service in aiohttp #2

Dismiss ▾

 Open Opened 2 days ago on aiohttp (pip) · requirements.txt

Package	Affected versions	Patched version
 aiohttp (pip)	≤ 3.8.1	None

Severity

Moderate

aiohttp v3.8.1 was discovered to contain an invalid IPv6 URL which can lead to a Denial of Service (DoS).

Weaknesses

No CWEs

CVE ID

CVE-2022-33124

GHSA ID

GHSA-nwqr-c348-m5wr

 See advisory in GitHub Advisory Database

 See all of your affected repositories

aiohttp v3.8.1 was discovered to **contain an invalid IPv6 URL** which can lead to a Denial of Service (DoS).

I can't say anything but lol

So, please show your "example of a context in which denial of service would occur". Don't make unnecessary misunderstandings happen (already happened if it does not be a vulnerability since a CVE-ID has been registered).

12

webknjaz on Jun 27, 2022 · edited by webknjaz

Edits ▾

Member



```
$ python -m pip show aiohttp
latest
```



I also wonder what the `latest` means in this context. Since it's clearly not an output that the above command produces but something user-invented, it's hard to judge what it refers to. Is it the latest version published to PyPI? Or is it something built from source. (I think it's the latter because of how the paths show up in the traceback).

If it's been built from the source, there's more questions to answer on how it's been built and whether it was built from the HEAD of this repo's default branch or maybe from a minor version branch HEAD. Without this, it's hard to guess what exactly this issue is implying even.

webknjaz on Jun 27, 2022

Member



I can't say anything but lol

Exactly what I was thinking. Note that there's some discussions along the same lines @ [#6801](#).

woodruffw on Jun 27, 2022



For `pip-audit` users, you can temporarily ignore this disputed vulnerability using the `--ignore-vuln` flag:

```
$ pip-audit --ignore-vuln GHSA-rwqr-c348-m5wr
```



5

2



kaotisk-hund mentioned this [on Jun 28, 2022](#)

✓ [aiohttp 3.8.1 vulnerability StellarCN/py-stellar-base#602](#)

DavidKorczynski on Jul 3, 2022



I'm the author of the fuzzers in the OSS-Fuzz repo (<https://github.com/google/oss-fuzz/tree/master/projects/aiohttp>). Sorry to see this mess -- the CVE filing or security filing does not come from OSS-Fuzz and am not sure who files them. This has previously happened, e.g. see this OSS-Fuzz issue which deals with unknown CVE filings [google/oss-fuzz#7146](https://github.com/google/oss-fuzz/issues/7146).

In this context, I would be happy to develop the fuzzing suite into aiohttp and submit it all upstream so you can review and ensure it matches your threat model, i.e. I would be happy to revive this PR [#5320](#)

Again, many apologies that this false security filing happened.

4 1

tooptoop4 on Jul 27, 2022 · Hidden as spam

webknjaz on Aug 10, 2022

Member ...

I would be happy to revive this PR [#5320](#)

Yeah, that could be useful but in order to proceed, it really has to be integrated into the pytest setup we've got first, as I mentioned earlier: [#5320 \(review\)](#). Running the fuzzers could be controlled by pytest markers, for example.

  **DavidKorczynski** mentioned this [on Aug 10, 2022](#)

 [Added first fuzzers as step in OSS-Fuzz integration. #5320](#)

25 remaining items

Load more

woodruffw on Nov 8, 2023

Ah yep, I knew I remembered this: [pypa/advisory-database#83](#)

1

  **woodruffw** mentioned this [on Nov 8, 2023](#)

 [aiohttp: withdraw PYSEC-2022-43059 pypa/advisory-database#169](#)

webknjaz on Nov 8, 2023

Member ...

Oh, again? Urgh.. I suppose MITRE is ghosting all of us 🙄

woodruffw on Nov 8, 2023

Yep ☹️

From a quick look, I think what happened here is that the GHSA advisory was correctly withdrawn, but (as we all know) the CVE never was. PYSEC didn't actually have an "active" advisory open for this until the CVE one got merged in somehow, causing it to ignore the fact that it's already been withdrawn.



fniessink added 2 commits that reference this issue on Nov 8, 2023

Ignore CVE PYSEC-2022-43059, see [aio-libs/aiohttp#6772](#).

3d498ad

Ignore CVE PYSEC-2022-43059, see [aio-libs/aiohttp#6772](#).

bad94c4

woodruffw on Nov 8, 2023

This is now withdrawn from both PYSEC and GHSA, as of [pypa/advisory-database#169](#).

There's been no update from MITRE, so I think we can safely assume that they're not going to perform any diligence here.

@webknjaz Give the above, I think this is safe to close. WDYT?

♥️ 2

webknjaz on Nov 28, 2023 · edited by webknjaz

Edits ▾

Member

@woodruffw fair enough. Closing... Thanks everyone involved/annoyed :)

P.S. The latest update on the CVE page, down in the history:

CPE Deprecation Remap by NIST 11/22/2023 12:09:17 PM

Action	Type	Old Value	
Changed	CPE Configuration	OR *cpe:2.3:a:aiohttp_project:aiohttp:3.8.1:*:*:*:*:*:*	O *

♥️ 1



webknjaz closed this as not planned on Nov 28, 2023



webknjaz mentioned this on Jul 1, 2024

[\[GHSA-78xj-cgh5-2h22\] NPM IP package vulnerable to Server-Side Request Forgery \(SSRF\) attacks github/advisory-database#3504](#)



webknjaz added **wontfix** **reproducer: missi...** and removed **bug** on Jul 1, 2024



webknjaz changed the title ~~invalid IPv6 URL~~ <This issue is referenced from a **SPAM**/nonsense CVE with no explanation and no good reason. Ignore it as there is no actual vulnerability here> on Jul 1, 2024



! **NotSqrt** mentioned this [on Aug 22, 2025](#)

✓ [Handle withdrawn PYSEC nyudenkov/pysentry#54](#)

[Sign up for free](#) to join this conversation on **GitHub**. Already have an account? [Sign in to comment](#)

Assignees

No one assigned

Labels

invalid

reproducer: missing

wontfix

Type

No type

Projects

No projects

Milestone

No milestone

Relationships

None yet

Development



Code with agent mode



No branches or pull requests

Participants



+7